



İSTANBUL ÜNİVERSİTESİ – CERRAHPAŞA
Bilgi İşlem Daire Başkanlığı · Sistem ve Güvenlik Birimi

Websitesi Güvenlik Analizi Raporu

Cerrahpaşa Tıp Fakültesi Aday Öğrenci Tanıtım Sitesi
Kaynak Kod & Altyapı Güvenlik Değerlendirmesi

RAPOR TARİHİ

18 Mayıs 2026

RAPOR NO

IUC-SGB-2026-017

ANALİZ TÜRÜ

Statik Kod + Bağımlılık Analizi

DURUM

Taslak

KURUMA ÖZEL · GİZLİLİK DERECEİ: HİZMET İÇİ



İÇİNDEKİLER

1. Yönetici Özeti
2. Analiz Kapsamı ve Metodoloji
3. Proje Mimarisi
4. Güvenlik Bulguları
 - [B-01 · Kritik Bağımlılık Açıkları \(15 GHSA\)](#)
 - [B-02 · Gizli Bilgi Yönetimi ve .env Güvenliği](#)
 - [B-03 · Supabase API Anahtarı ve RLS Eksikliği](#)
 - [B-04 · Admin Paneli Güvenlik Sorunları](#)
 - [B-05 · HTTP Güvenlik Başlıkları Eksikliği](#)
 - [B-06 · iframe Güvenlik Zafiyetleri](#)
 - [B-07 · TypeScript Hata Bastırma](#)
 - [B-08 · Veri Kaynağı Tutarsızlığı](#)
 - [B-09 · Form Güvenliği ve KVKK Uyumu](#)
 - [B-10 · Tamamlanmamış Üretim Bileşenleri](#)
5. Risk Matrisi
6. Hestia Uyumluluğu ve PHP Dönüşüm Analizi
7. Güvenli Admin Paneli Mimari Önerisi
8. Öncelikli Aksiyon Planı
9. Sonuç

1. Yönetici Özeti

Bu rapor, İstanbul Üniversitesi-Cerrahpaşa Tıp Fakültesi'nin aday öğrenci tanıtım web sitesinin (**cerrahpasa-tanitim**) kaynak kodu, bağımlılık yapısı ve altyapı konfigürasyonu üzerinde gerçekleştirilen güvenlik analizi bulgularını içermektedir. Analiz; statik kod inceleme, npm bağımlılık denetimi ve konfigürasyon gözden geçirme yöntemleriyle yürütülmüştür.

Analiz kapsamında **10 adet güvenlik bulgusu** tespit edilmiş olup bunlardan **2 tanesi KRİTİK**, **4 tanesi YÜKSEK**, **3 tanesi ORTA** ve **1 tanesi DÜŞÜK** seviyede değerlendirilmiştir. Ayrıca proje bağımlılıklarında toplam **15 adet bilinen güvenlik açığı (GHSA)** tespit edilmiştir.

En kritik bulgu: Projenin kullandığı Next.js çerçevesi, aktif olarak yararlanılabilir Middleware atlatma, Sunucu Tarafı İstek Sahteciliği (SSRF) ve Önbellek Zehirlleme açıklarını içermektedir. Ayrıca Supabase veritabanı erişim anahtarının istemci tarafında açık bulunması ve Row Level Security (RLS) politikalarının doğrulanmamış olması, veritabanı yetkisiz erişim riskini doğrudan artırmaktadır.

Sitenin kurumsal altyapıda yayına alınmadan önce bu rapordaki bulguların tamamının giderilmesi **şiddetle tavsiye edilir**.



2. Analiz Kapsamı ve Metodoloji

2.1 Kapsam

Kapsam Alanı	Detay	Dahil mi?
Kaynak Kod (statik analiz)	Tüm bileşenler, konfigürasyon dosyaları	✓ Evet
Bağımlılık Analizi	npm audit, GHSA veritabanı karşılaştırması	✓ Evet
Konfigürasyon Denetimi	.env, next.config.mjs, tsconfig, admin config	✓ Evet
Altyapı Analizi	Supabase bağlantısı, CMS yapısı	✓ Evet
Dinamik Test (DAST)	Canlı uygulama üzerinde saldırı simülasyonu	✗ Hayır (kapsam dışı)
Penetrasyon Testi	Aktif zafiyet istismarı	✗ Hayır (kapsam dışı)
Supabase RLS Politikaları	Dashboard erişimi gerektiriyor	⚠ Kısmi

2.2 Metodoloji

- Statik Kod Analizi (SAST):** Tüm TypeScript/TSX bileşenleri, konfigürasyon dosyaları ve ortam değişkeni kullanımı manuel incelendi.
- Bağımlılık Denetimi:** npm audit çıktısı GitHub Security Advisory (GHSA) veritabanıyla karşılaştırıldı.
- Konfigürasyon Gözden Geçirme:** Next.js, Tailwind, TypeScript ve CMS konfigürasyonları güvenlik en iyi pratikleri çerçevesinde değerlendirildi.
- Mimari İnceleme:** Veri akışı, kimlik doğrulama mekanizmaları ve üçüncü taraf entegrasyonları analiz edildi.

2.3 Analiz Edilen Dosyalar

Dosya / Dizin	Satır Sayısı	Amaç
app/page.tsx	27	Ana sayfa bileşen düzenleyicisi
app/layout.tsx	60	Kök layout, meta veriler
components/faq-section.tsx	105	SSS – Supabase bağlantısı
components/announcements-section.tsx	167	Duyurular – Supabase bağlantısı
components/contact-section.tsx	95	İletişim – Google Maps iframe
components/hero.tsx	122	Kapak – YouTube iframe
components/forms-section.tsx	77	Formlar bölümü
components/navbar.tsx	105	Navigasyon

components/about-section.tsx	140	Hakkımızda
components/instagram-section.tsx	85	Sosyal medya
components/guide-section.tsx	344	Rehber bölümü
components/footer.tsx	68	Alt bilgi
public/admin/config.yml	50	CMS konfigürasyonu
public/admin/index.html	14	CMS giriş sayfası
.env.local	3	Ortam değişkenleri
next.config.mjs	11	Next.js konfigürasyonu
.gitignore	16	Git dışlama kuralları
package.json	73	Bağımlılık tanımları
data/announcements.json	50	Statik duyuru verisi
data/faqs.json	63	Statik SSS verisi

3. Proje Mimarisi

3.1 Teknoloji Yığını

Katman	Teknoloji	Versiyon	Not
Çerçeve	Next.js (App Router)	16.2.0	⚠️ Açık içeriyor
Dil	TypeScript	5.7.3	✅
Stil	Tailwind CSS	4.2.0	✅
UI Bileşenleri	Radix UI + shadcn/ui	Çeşitli	✅
Veritabanı	Supabase (PostgreSQL)	2.38.0	⚠️ RLS doğrulanmamış
CMS	Netlify CMS (Decap CMS)	2.x	❌ Çalışmıyor
Analitik	Vercel Analytics	1.6.1	✅ Sadece prod.
CSS İşlemci	PostCSS	<8.5.10	⚠️ Açık içeriyor

3.2 Veri Akışı

```
/* Mevcut (Sorunlu) Veri Akışı */ Kullanıcı Tarayıcısı | ▼ Next.js App Router  
(SSR/CSR karışık) | |—— [SSS, Duyurular] ———> Supabase REST API | (anon key  
tarayıcıda görünür) | |—— [Rehber, İletişim] ———> Statik JSX (hardcoded) | |——  
[Admin CMS] ———> Netlify CMS → GitHub Repo | (çalışmıyor, tutarsız) | |——  
[Formlar] ———> Google Forms (placeholder URL)
```

3.3 Bileşen Haritası

Bileşen	Veri Kaynağı	Dinamik mi?	Güvenlik Notu
Navbar	Hardcoded	Hayır	✅
Hero	Hardcoded + YouTube	Kısmi	⚠️ iframe
GuideSection	Hardcoded JSX	Hayır	✅
FaqSection	Supabase (client)	Evet	❌ Anon key açık
AnnouncementsSection	Supabase (client)	Evet	❌ Anon key açık
FormsSection	Hardcoded	Hayır	⚠️ Placeholder URL
InstagramSection	Mock data	Hayır	⚠️ Sahte içerik

AboutSection	Hardcoded + placeholder	Hayır	⚠ Placeholder isimler
ContactSection	Hardcoded + Maps	Kısmi	⚠ iframe
Footer	Hardcoded	Hayır	✅



4. Güvenlik Bulguları

CVSS SKORU

7.5 – 9.1 (Yüksek-Kritik)

ETKİLENEN DOSYA

package.json

ETKİLENEN SÜRÜM

Next.js 16.2.0, PostCSS <8.5.10

Açıklama: Proje, birden fazla aktif güvenlik açığı içeren Next.js 16.2.0 sürümünü kullanmaktadır. npm audit komutu çalıştırıldığında 1 yüksek seviyeli (HIGH) ve 1 orta seviyeli (MODERATE) bağımlılık zafiyeti raporlanmaktadır; ancak bu 2 ana güvenlik danışması altında toplam **15 GHSA referansı** bulunmaktadır.

```
next 9.3.4-canary.0 - 16.3.0-canary.5 Severity: HIGH postcss <8.5.10
Severity: moderate 2 vulnerabilities (1 moderate, 1 high)
```

Terminal: npm audit çıktısı

Tespit Edilen GHSA Referansları:

GHSA-q4gf-8mx6-v5v3

GHSA-8h8q-6873-q5fj

GHSA-26hh-7cqf-hhc6

GHSA-3g8h-86w9-wvmq

GHSA-ffhc-5mcf-pf4q

GHSA-vfv6-92ff-j949

GHSA-gx5p-jg67-6x7h

GHSA-mg66-mrh9-m8jx

GHSA-h64f-5h5j-jqjh

GHSA-c4j6-fc7j-m34r

GHSA-492v-c6pp-mqqv

GHSA-wfc6-r584-vfw7

GHSA-267c-6grr-h53f

GHSA-36qx-fr4f-26g5

GHSA-qx2v-qp2m-jg93

GHSA Kodu	Zafiyet Türü	Etkilenen Bileşen	Önem
GHSA-q4gf-8mx6-v5v3	Denial of Service – Server Components	Next.js	YÜKSEK
GHSA-8h8q-6873-q5fj	Denial of Service – Server Components (2)	Next.js	YÜKSEK
GHSA-mg66-mrh9-m8jx	DoS – Bağlantı tükenmesi (Cache Components)	Next.js	YÜKSEK
GHSA-h64f-5h5j-jqjh	DoS – Görsel Optimizasyon API	Next.js	YÜKSEK
GHSA-c4j6-fc7j-m34r	SSRF – WebSocket yükseltme	Next.js	KRİTİK
GHSA-26hh-7cqf-hhc6	Middleware/Proxy atlatma (tamamlanmamış düzeltme)	Next.js	KRİTİK
GHSA-492v-c6pp-mqqv	Middleware atlatma – dinamik route parametresi	Next.js	YÜKSEK
GHSA-267c-6grr-h53f	Middleware/Proxy atlatma	Next.js	YÜKSEK
GHSA-36qx-fr4f-26g5	Middleware/Proxy atlatma – i18n (Pages Router)	Next.js	ORTA

GHSA-3g8h-86w9-wvmq	Önbellek zehirlleme – Middleware/Proxy yönlendirme	Next.js	YÜKSEK
GHSA-wfc6-r584-vfw7	Önbellek zehirlleme – RSC yanıtları	Next.js	YÜKSEK
GHSA-vfv6-92ff-j949	Önbellek zehirlleme – RSC cache-busting	Next.js	ORTA
GHSA-ffhc-5mcf-pf4q	XSS – App Router CSP nonce	Next.js	YÜKSEK
GHSA-gx5p-jg67-6x7h	XSS – beforeInteractive script	Next.js	YÜKSEK
GHSA-qx2v-qp2m-jg93	XSS – </style> kaçış hatası	PostCSS	ORTA

⚠️ **Önemli Not:** GHSA-c4j6-fc7j-m34r (SSRF) ve GHSA-26hh-7cqf-hhc6 (Middleware atlatma) açıkları, saldırganın sunucu tarafında yetkisiz istekler göndermesine veya kimlik doğrulama mekanizmalarını atlatmasına olanak tanır. Bu açıklar aktif olarak istismar edilmektedir.

Etkilenen package.json Satırı

```
// Mevcut (açık içeren):  
"next": "16.2.0",  
// Güvenli sürüm: "next": "16.2.6", // veya en güncel stabil sürüm
```

✅ ÇÖZÜM ÖNERİSİ

- Next.js'i en az **16.2.6** sürümüne güncelleyin: `npm install next@latest`
- PostCSS bağımlılığını güncelleyin: `npm audit fix --force`
- Güncelleme sonrası `npm audit` ile doğrulama yapın
- Otomatik bağımlılık güncellemesi için **Dependabot** veya **Renovate Bot** yapılandırın
- Aylık bağımlılık denetimini süreç haline getirin

ETKİLENEN DOSYA

.env.local, .gitignore, public/admin/config.yml

RİSK

Kimlik bilgisi sızıntısı, yetkisiz veritabanı erişimi

Açıklama: Projenin gizli bilgi yönetiminde birden fazla sorun tespit edilmiştir.

2.1 · .gitignore Kapsamı Yetersiz

```
# Mevcut kural — sadece .local uzantılıları korur:
.env*.local
Korunmayan durumlar: # .env ← commit'e girer! # .env.production ← commit'e girer! # .env.staging ← commit'e girer!
```

2.2 · NEXT_PUBLIC_ Prefix Kullanımının Riskleri

```
NEXT_PUBLIC_SUPABASE_URL=https://lecpcxkhgcm Lukeznrk.supabase.co
NEXT_PUBLIC_SUPABASE_PUBLISHABLE_KEY=sb_publishable_ZgP1B_aDCf8XeNQSupPqUg_VLbXk
NEXT_PUBLIC_SUPABASE_ANON_KEY=sb_publishable_ZgP1B_aDCf8XeNQSupPqUg_VLbXkepD
```

NEXT_PUBLIC_ öneki taşıyan tüm değişkenler Next.js tarafından derleme aşamasında JavaScript bundle'ına gömülür ve **tarayıcıda herkese açık hale gelir**. Bu değerler F12 geliştirici araçları veya kaynak kodu görüntüleme ile herkes tarafından okunabilir.

2.3 · GitHub Reposunda Açık Yapılandırma

```
backend: name: github
repo: mstfavelibeyoglu/cerrahpasa-tanitim
Repo adı açık branch: main auth_endpoint: api/auth
```

Bu yapılandırma dosyası public/ dizininde bulunduğu için, site canlıya alındığında <https://siteniz.com/admin/config.yml> URL'sinden herkes tarafından erişilebilir olacaktır. İçeriği; GitHub repo adresi, branch adı ve auth endpoint bilgilerini açığa çıkarmaktadır.

2.4 · Git Geçmişinde Sızıntı Riski

Geliştirme sürecinde herhangi bir noktada .env dosyası (local eki olmadan) yanlışlıkla commit edilmişse ve sonradan silinmişse, git geçmişinden hâlâ alınabilir:

```
# Saldırgan bu komutla geçmişi arar: git log --all --full-history --
"**/.env*" git show <commit-hash>:.env
```

✓ ÇÖZÜM ÖNERİSİ

- .gitignore dosyasını tüm .env varyantlarını kapsayacak şekilde güncelleyin:

```
# Güvenli .gitignore: .env .env.* !.env.example # sadece örnek dosyayı  
dahil et
```

- .env.example dosyası oluşturun — gerçek değer yok, sadece anahtar isimleri:

```
# .env.example (GitHub'a commit edilebilir) NEXT_PUBLIC_SUPABASE_URL=  
NEXT_PUBLIC_SUPABASE_ANON_KEY= SUPABASE_SERVICE_ROLE_KEY= # NEXT_PUBLIC  
olmadan! Sunucu tarafı için
```

- Git geçmişinde gizli bilgi olup olmadığını **git-secrets** veya **truffleHog** ile tarayın
- Geçmişte sızıntı varsa ilgili Supabase anahtarlarını hemen döndürün (rotate)
- public/admin/config.yml dosyasını public/ dışına taşıyın veya hassas bilgileri env ile yönetin

ETKİLENEN DOSYALAR

faq-section.tsx, announcements-section.tsx

RİSK

Yetkisiz veri okuma/yazma, veri sızıntısı

ETKİLENEN TABLO

faqs, announcements

3.1 · Her Bileşende Ayrı Client Oluşturma

```
import { createClient } from "@supabase/supabase-js" // components/faq-section.tsx — Satır 11-16
// ❌ Her bileşen kendi client'ını oluşturuyor
const supabase = createClient(
  process.env.NEXT_PUBLIC_SUPABASE_URL!,
  process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY! // Tarayıcıda görünür!
)
```

```
// ❌ Aynı sorun ikinci bileşende de tekrarlanıyor components/announcements-section.tsx — Satır 17-20
const supabase = createClient(
  process.env.NEXT_PUBLIC_SUPABASE_URL!,
  process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY!
)
```

3.2 · Anahtarın Tarayıcıda Görünürlüğü

Derleme sonrasında bundle dosyasında anon key açıkça bulunmaktadır:

```
const supabase = createClient( "https://lecxpcxkhgcm Lukeznrk.supabase.co",
process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY // Derleme sonrası string'e
çevrilir
);
```

3.3 · RLS Olmadığında İstismar Senaryosu

Row Level Security (RLS) politikası tanımlı değilse, herhangi bir kişi aşağıdaki komutla tüm veritabanına erişebilir:

```
# Tarayıcıdan alınan anon key ile doğrudan Supabase API çağırısı: curl
'https://lecxpcxkhgcm Lukeznrk.supabase.co/rest/v1/faqs' \ -H 'apikey:
sb_publishable_ZgP1B_...' \ -H 'Authorization: Bearer
sb_publishable_ZgP1B_...' # RLS yoksa tüm tablo döner. Yazma erişimi de
açıksa: curl -X POST
'https://lecxpcxkhgcm Lukeznrk.supabase.co/rest/v1/announcements' \ -H
'apikey: sb_publishable_ZgP1B_...' \ -H 'Content-Type: application/json' \ -d
'{"title":"Sahte Duyuru","description":"Manipüle edilmiş içerik"}'
```

✓ ÇÖZÜM ÖNERİSİ

- **Supabase Dashboard** → **Authentication** → **Policies** bölümünde tüm tablolar için RLS'yi etkinleştirin:

```
-- Supabase SQL Editor'da çalıştırın: -- 1. RLS'yi etkinleştir: ALTER
TABLE faqs ENABLE ROW LEVEL SECURITY; ALTER TABLE announcements ENABLE
ROW LEVEL SECURITY; -- 2. Sadece okuma izni ver (anonim kullanıcılar):
CREATE POLICY "public_read_faqs" ON faqs FOR SELECT TO anon USING
(true); CREATE POLICY "public_read_announcements" ON announcements FOR
SELECT TO anon USING (true); -- 3. Yazma işlemleri için service_role
key zorunlu kıl -- (authenticated veya service_role dışında
INSERT/UPDATE/DELETE yok)
```

- Merkezi Supabase client oluşturun:

```
import { createClient } from '@supabase/supabase-js' export const
supabase = createClient( process.env.NEXT_PUBLIC_SUPABASE_URL!,
process.env.NEXT_PUBLIC_SUPABASE_ANON_KEY! )
```

- Tüm bileşenlerde import { supabase } from '@lib/supabase' kullanın
- Admin işlemleri için SUPABASE_SERVICE_ROLE_KEY kullanın — ama **asla NEXT_PUBLIC_ ile değil**, sadece sunucu tarafı API route'larında



ETKİLENEN DOSYALAR

public/admin/index.html, public/admin/config.yml

RİSK

Yetkisiz erişim, kimlik doğrulama atlatma, içerik manipülasyonu

4.1 Cakisan Kimlik Dogrulama Sistemleri

```
<script src="https://identity.netlify.com/v1/netlify-identity-widget.js">
</script> <!-- Netlify Identity - sadece Netlify hosting ile calisir -->
<script src="https://unpkg.com/netlify-cms@2.0.0/dist/netlify-cms.js">
</script>
```

```
backend: name: github # GitHub OAuth - farkli sistem! repo:
mstfavelibeyoglu/cerrahpasa-tanitim branch: main auth_endpoint: api/auth # Bu
endpoint Next.js'te TANIMLI DEGIL!
```

Tespit: index.html Netlify Identity yuklarken config.yml GitHub OAuth ile api/auth referans aliyor. Bu endpoint mevcut degil. Giris her durumda basarisiz oluyor.

Guvenlik Katmani	Durum	Risk
reCAPTCHA / Bot Korumasi	Yok	Brute-force saldirisi
lki Faktorlu Dogrulama (2FA)	Yok	Kimlik bilgisi calinirsa tam erisim
Giris Denemesi Sinirlamasi	Yok	Kaba kuvvet saldirisi
IP Kisitlamasi / Whitelist	Yok	Kuresel erisim mumkun
Oturum Suresi Siniri	Yok	Uzun sureli yetkisiz oturum
Erisim Kayitlari (Audit Log)	Yok	Yetkisiz erisim tespit edilemez
CSRF Korumasi	Yok	Oturum calma sonrasi eylem sahteciligi

COZUM ONERISI

- Netlify CMS yerine Supabase tabanli ozel admin paneli gelistirin (Bolum 7)
- Admin route tahmin edilemez path ile gizleyin: /admin mevcut yerine /iuc-yonetim-2026
- Next.js Middleware ile kampus IP whitelist uygulayin
- Google reCAPTCHA v3 + Supabase Auth 2FA entegrasyonu ekleyin
- Tum admin islemlerini audit_log tablosuna kaydedin

ETKİLENEN DOSYA

next.config.mjs

RISK

XSS, Clickjacking, MIME sniffing, bilgi sızıntısı

```
const nextConfig = { typescript: { ignoreBuildErrors: true, // B-07 bulgusu }, images: { unoptimized: true }, // headers() fonksiyonu YOK - tum guvenlik basliklari eksik } export default nextConfig
```

next.config.mjs - Tum dosya (mevcut durum)

HTTP Basligi	Korudugu Saldiri	Durum
Content-Security-Policy	XSS, veri enjeksiyonu	Eksik
X-Frame-Options: SAMEORIGIN	Clickjacking	Eksik
X-Content-Type-Options: nosniff	MIME tipi sahteciligi	Eksik
Strict-Transport-Security	SSL soyma saldirisi	Eksik
Referrer-Policy	Referrer bilgisi sızıntısı	Eksik
Permissions-Policy	Kamera/mikrofon kötüye kullanımı	Eksik

COZUM - NEXT.CONFIG.MJS GUNCELLENMİS

```
const securityHeaders = [ { key: 'Strict-Transport-Security', value: 'max-age=63072000; includeSubDomains; preload' }, { key: 'X-Frame-Options', value: 'SAMEORIGIN' }, { key: 'X-Content-Type-Options', value: 'nosniff' }, { key: 'Referrer-Policy', value: 'strict-origin-when-cross-origin' }, { key: 'Permissions-Policy', value: 'camera=(), microphone=(), geolocation=()' }, { key: 'Content-Security-Policy', value: "default-src 'self'; " + "script-src 'self' 'unsafe-inline' https://www.youtube.com; " + "frame-src https://www.youtube.com https://www.google.com; " + "img-src 'self' data: https://*.supabase.co; " + "connect-src 'self' https://*.supabase.co" }, ] const nextConfig = { typescript: { ignoreBuildErrors: false }, images: { unoptimized: true }, async headers() { return [{ source: '/(.*)', headers: securityHeaders }] }, } export default nextConfig
```



```
components/hero.tsx - Satir 81-88 (YouTube iframe)
<iframe allow="accelerometer; autoplay; clipboard-write; encrypted-media;
gyroscope; picture-in-picture" /* clipboard-write: kullanıcı panosuna yazma
izni - GEREKSİZ! */ /* sandbox attribute YOK */ />
```

```
components/contact-section.tsx - Satir 79-90 (Google Maps iframe)
<iframe referrerPolicy="no-referrer-when-downgrade" /* Zayıf politika */
/* sandbox attribute YOK */ />
```

COZUM ONERISI

```
{/* YouTube - duzeltilmis: clipboard-write kaldırıldı, sandbox eklendi
*/} <iframe allow="accelerometer; autoplay; encrypted-media; picture-
in-picture" sandbox="allow-scripts allow-same-origin allow-
presentation" referrerPolicy="strict-origin-when-cross-origin"
allowFullScreen /> /* Google Maps - duzeltilmis */ <iframe
sandbox="allow-scripts allow-same-origin" referrerPolicy="strict-
origin-when-cross-origin" loading="lazy" />
```

```
typescript: { ignoreBuildErrors: true, // TypeScript hataları üretimde
gizleniyor }, next.config.mjs - Satir 3-5
```

Bu ayar tip hatalarının build'i engellemesini devre dışı bırakır. Güvenlik açığı içeren yanlış tip kullanımlarından kaynaklanan hatalar sessizce üretime taşınabilir.

COZUM

- ignoreBuildErrors: false yapın veya satiri tamamen silin (varsayılan false'dur)
- Mevcut hataları görmek için: `npx tsc --noEmit`
- CI/CD pipeline'a TypeScript kontrolü ekleyin

Kaynak	Ne icin?	Kim yaziyor?	Kim okuyor?	Durum
data/announcements.json	Duyurular	Netlify CMS	Kimse	Kullanilmiyor
data/faqs.json	SSS	Netlify CMS	Kimse	Kullanilmiyor
Supabase faqs tablosu	SSS	Supabase Dashboard	faq-section.tsx	Aktif
Supabase announcements tablosu	Duyurular	Supabase Dashboard	announcements-section.tsx	Aktif

Senaryo: Yoneticisi CMS'e duyuru ekler, JSON dosyasi guncellenir, site Supabase'den okur, duyuru sitede gorunmez. Hem operasyonel hem guvenlik riski.

COZUM

- Tek veri kaynagi olarak Supabase'i secin (onerilen)
- Kullanilmayan data/*.json dosyalarini ve Netlify CMS'i kaldirin
- Admin islemlerini Supabase Dashboard veya ozel admin sayfasi uzerinden yonetin

```
components/forms-section.tsx - Satir 11-29
const forms = [ { id: 1, title: "Tanitim Anketi", url:
"https://forms.google.com", // TODO - Gercek URL yok! }, { id: 2, title:
"Basvuru Formu", url: "https://forms.google.com", // TODO - Gercek URL yok!
}, { id: 3, title: "Soru ve Gorusv Formu", url: "https://forms.google.com",
// TODO - Gercek URL yok! }, ]
```

- Tum form baglantilari placeholder, gercek form yok
- Google Forms verileri Google sunucularina (ABD) aktarir - KVKK Madde 9 yurt disi veri aktarimi hukmu
- KVKK aydinlatma metni baglantisi yok, acik riza mekanizmasi yok
- reCAPTCHA veya bot korumasi yok

COZUM ONERISI

- Google Forms yerine Supabase tabanlı kurum ici form cozumu degerlendirin
- Google Forms kullanilacaksa: KVKK aydinlatma metni ve acik riza onay kutucugu ekleyin
- reCAPTCHA v3 entegrasyonu zorunlu kilin
- Rate limiting: ayni IP'den dakikada max 3 form gonderimi
- Gercek URL'leri yayin oncesinde tanimlayin

```
// Gercek Instagram entegrasyonu yok, sahte veri gosteriliyor: const
mockPosts = [ { id: 1, color: "bg-primary/20" }, // Gercek gorsel yok { id:
2, color: "bg-secondary/30" }, // ... 9 adet sahte renk bloku ]
```

```
const teamMembers = [ { name: "Isim Soyisim", role: "Gorev / Rol" }, //
Placeholder! { name: "Isim Soyisim", role: "Gorev / Rol" }, // ... 6 adet
placeholder ]
```

COZUM

- Gercek ekip bilgilerini about-section.tsx'e ekleyin veya Supabase'den cekin
- Instagram icin Meta Graph API entegrasyonu veya statik secilmis galeri kullanin
- Tum placeholder icerikler yayin oncesinde tamamlanmali

5. Risk Matrisi

Bulgu	Baslik	Olasilik	Etki	Risk	Oncelik
B-01	15 GHSA Bagimlilik Acigi	Yuksek	Kritik	KRITIK	1 - Acil
B-02	Gizli Bilgi / .env Guvenligi	Yuksek	Kritik	KRITIK	1 - Acil
B-03	Supabase Anon Key + RLS	Yuksek	Yuksek	YUKSEK	2 - Bu hafta
B-04	Admin Paneli Guvensiz	Orta	Yuksek	YUKSEK	2 - Bu hafta
B-05	HTTP Guvenlik Basliklari Yok	Orta	Yuksek	YUKSEK	2 - Bu hafta
B-09	Form Guvenligi + KVKK	Yuksek	Orta	YUKSEK	2 - Bu hafta
B-06	iframe Guvenligi	Dusuk	Orta	ORTA	3 - Bu ay
B-07	TypeScript Hata Bastirma	Orta	Orta	ORTA	3 - Bu ay
B-08	Veri Kaynagi Tutarsizligi	Yuksek	Dusuk	ORTA	3 - Bu ay
B-10	Tamamlanmamis Bilesenleri	Yuksek	Dusuk	DUSUK	4 - Yayin oncesi

6. Hestia Uyumlulugu ve Dagitim Secenekleri

HestiaCP, PHP/Apache/Nginx ortamlari icin tasarlanmis bir kontrol panelidir. Bu proje Node.js runtime gerektiren bir Next.js uygulamasidir ve dogrudan PHP ortaminda calistirilamaz.

Secenek A - Statik Export + Hestia (Onerileni / En Hizli)

```
// next.config.mjs degisikligi: const nextConfig = { output: 'export', // Statik
HTML/CSS/JS uretir images: { unoptimized: true }, } // Build ve deploy adimlari: //
1. npm run build -> out/ klasoru olusur // 2. out/ icerigini Hestia web root'una
kopyalayin: // /home/kullanici/web/ctf.cerrahpasa.iuc.edu.tr/public_html/
```

Secenek B - Node.js + PM2 + Nginx Reverse Proxy (Tam Cozum)

```
# 1. Sunucuda Node.js kurulu olmalı # 2. Build alın: npm run build # 3. PM2 ile
baslatın: pm2 start npm --name "ctf-tanitim" -- start pm2 save && pm2 startup # 4.
Hestia Nginx custom template (nginx.conf): server { listen 443 ssl; server_name
ctf.cerrahpasa.iuc.edu.tr; # Guvenlik basliklari: add_header Strict-Transport-
Security "max-age=63072000" always; add_header X-Frame-Options SAMEORIGIN always;
add_header X-Content-Type-Options nosniff always; location / { proxy_pass
http://127.0.0.1:3000; proxy_set_header Host $host; proxy_set_header X-Real-IP
$remote_addr; proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for; } }
```

Secenek	Sure	Karmasiklik	Tam Ozellik	Oneri
A - Statik Export	1-2 gun	Dusuk	%90	Hizli cozum
B - Node.js + Nginx	2-3 gun	Orta	%100	En iyi
C - PHP Donusum	3-4 hafta	Cok yuksek	%70	Tavsiye edilmez
D - Vercel/Netlify	1 saat	Cok dusuk	%100	En kolay

7. Guvenli Admin Paneli Mimari Onerisi

7.1 Onerilen Mimari Akisi

```
Admin (yetkili kullanıcı) | v /iuc-yonetim-2026/giris |-- reCAPTCHA v3 dogrulama |--  
- Supabase Auth (email + sifre) +-- TOTP / 2FA (Google Authenticator) | v (basarili  
giris) /iuc-yonetim-2026/panel |-- Duyuru Yonetimi --> /api/admin/duyurular  
(service_role key) |-- SSS Yonetimi --> /api/admin/sss (service_role key) +--  
Iletisim Bilgisi --> /api/admin/iletisim (service_role key) | audit_log tablosuna  
kayit (IP, zaman, kullanıcı, islem)
```

7.2 Guvenli API Route Ornegi

```
import { createClient } from '@supabase/supabase-js' import { NextRequest, app/api/admin/duyurular/route.ts  
NextResponse } from 'next/server' // SERVICE_ROLE - NEXT_PUBLIC degil, sunucu  
tarafi const adminClient = createClient( process.env.NEXT_PUBLIC_SUPABASE_URL!,  
process.env.SUPABASE_SERVICE_ROLE_KEY! // Tarayicida asla gorunmez ) export async  
function POST(request: NextRequest) { // 1. JWT token ile oturumu dogrula const  
token = request.headers.get('Authorization')?.replace('Bearer ', '') const { data:  
{ user }, error } = await adminClient.auth.getUser(token!) if (error || !user)  
return NextResponse.json({ error: 'Yetkisiz' }, { status: 401 }) // 2. Veriyi al  
const body = await request.json() // 3. Veritabanina yaz const { data, error:  
dbError } = await adminClient .from('announcements').insert(body) if (dbError)  
return NextResponse.json({ error: dbError.message }, { status: 500 }) // 4. Audit  
log kaydi await adminClient.from('audit_log').insert({ action:  
'INSERT_ANNOUNCEMENT', user_id: user.id, ip_address: request.headers.get('x-  
forwarded-for'), created_at: new Date() }) return NextResponse.json({ success:  
true, data }) }
```

7.3 Gerekli Supabase Tablolari

```
-- Audit log tablosu: CREATE TABLE audit_log ( id BIGSERIAL PRIMARY KEY, action Supabase SQL Editor  
TEXT NOT NULL, user_id UUID REFERENCES auth.users, details JSONB, ip_address TEXT,  
created_at TIMESTAMPTZ DEFAULT NOW() ); ALTER TABLE audit_log ENABLE ROW LEVEL  
SECURITY; CREATE POLICY "service_only" ON audit_log USING (false); -- Admin  
kullanici tablosu: CREATE TABLE admin_users ( id UUID REFERENCES auth.users PRIMARY  
KEY, email TEXT NOT NULL, role TEXT DEFAULT 'editor', created_at TIMESTAMPTZ  
DEFAULT NOW() );
```

8. Oncelikli Aksiyon Plani

ONCELIK 1 - Acil (Yayin oncesi zorunlu)

#	Aksiyon	Sorumlu	Sure
1.1	Next.js guncellemesi: npm install next@latest	Gelistirici	30 dk
1.2	npm audit fix --force (PostCSS acigi)	Gelistirici	15 dk
1.3	.gitignore tum .env varyantlarini kapsamali	Gelistirici	5 dk
1.4	Supabase RLS etkinlestir (faqs, announcements tablolari)	Supabase Admin	30 dk
1.5	Git gecmisini truffleHog ile tara; gerekirse key dondurun	Guvenlik Birimi	1 saat

ONCELIK 2 - Bu hafta icinde

#	Aksiyon	Sorumlu	Sure
2.1	next.config.mjs'e guvenlik basliklarini ekle	Gelistirici	1 saat
2.2	ignoreBuildErrors: false yap, TypeScript hatalarini gider	Gelistirici	2-4 saat
2.3	iframe'lere sandbox ve dogru referrerPolicy ekle	Gelistirici	30 dk
2.4	Merkezi Supabase client olustur (lib/supabase.ts)	Gelistirici	30 dk
2.5	Hestia dagitim yontemini belirle (A veya B)	Sistem Birimi	1 gun

ONCELIK 3 - Bu ay icinde

#	Aksiyon	Sorumlu	Sure
3.1	Netlify CMS kaldir, Supabase tabanli ozel admin paneli yap	Gelistirici	3-5 gun
3.2	Admin paneline reCAPTCHA + 2FA + IP whitelist ekle	Gelistirici	2 gun
3.3	Tek veri kaynagi sec (Supabase onerilir)	Gelistirici	1 gun
3.4	KVKK aydinlatma metni ve form uyumu	Hukuk + Gelistirici	1 hafta
3.5	Dependabot ile otomatik bagimlilik guncellemesi	Gelistirici	1 saat

ONCELIK 4 - Yayin oncesi son kontrol

#	Aksiyon	Sorumlu	Sure
4.1	Tum placeholder icerikleri gercek verilerle degistir	Icerik ekibi	1-2 gun

4.2	Instagram gercek entegrasyonu veya statik galeri	Gelistirici	1 gun
4.3	Son npm audit kontrolu	Gelistirici	15 dk
4.4	securityheaders.com ile baslik dogrulamasi	Guvencuk Birimi	30 dk

9. Sonuc ve Degerlendirme

Gerceklestirilen guvenlik analizi sonucunda, Istanbul Universitesi-Cerrahpasa Tip Fakultesi Aday Ogrenci Tanitim Sitesi'nin mevcut haliyle kurumsal altyapida yayina alinmaya **hazir olmadigi** tespit edilmistir.

Projenin teknik altyapisi (Next.js, TypeScript, Radix UI, Supabase) modern ve uygun secimlerdir; tasarim kalitesi yuksektir. Ancak guvenlik konfigurasyonu yetersiz kalmistir. Tespit edilen bulgular buyuk olcude konfigurasyon eksikliklerinden ve tamamlanmamis ozelliklerden kaynaklanmakta olup temel mimarinin bastan degistirilmesini gerektirmemektedir.

Degerlendirme: Oncelik 1 ve 2 aksiyonlari uygulandiginda site kurumsal yayina hazir hale gelecektir. Tahmini toplam sure: 1-2 is gunu.

Raporu Hazirlayan	Tarih	Onaylayan	Revizyon
Sistem ve Guvencuk Birimi	18 Mayis 2026	Bilgi Islem Daire Baskanligi	v1.0 - Taslak